

1 Strict-Transport-Security (HSTS)

Purpose:

Forces the website to always use **HTTPS**, preventing TLS downgrade attacks.

Example:

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

Why it's important:

- Prevents attacker from forcing users to HTTP
- Blocks man-in-the-middle on public WiFi
- Required for strong security rating
- Protects cookies automatically

Test:

- Try loading site over HTTP → should redirect to HTTPS
- Missing header = **security misconfiguration**

2 Content-Security-Policy (CSP)

Purpose:

Prevents **Cross-Site Scripting (XSS)** and unwanted scripts.

Example:

Content-Security-Policy: default-src 'self';

Attack Prevention:

- Blocks injection of JavaScript
- Stops stealing cookies
- Blocks iframe phishing
- Stops form hijacking

Test:

- Try injecting `<script>alert(1)</script>`
- CSP should block it
- Verify in Developer Tools → Network → Headers

3 X-Frame-Options

Purpose:

Prevents **clickjacking attacks** by blocking embedding in iframes.

Example:

X-Frame-Options: DENY
or

X-Frame-Options: SAMEORIGIN

Test:

- Try loading site inside an iframe
- It should refuse to load

4 X-Content-Type-Options

Purpose:

Stops MIME-sniffing; prevents attacker from executing malicious files.

Example:

X-Content-Type-Options: nosniff

Test:

- Try uploading unusual file types
- Browser should not "guess" file type

5 Referrer-Policy

Purpose:

Prevents URL information leakage.

Example:

Referrer-Policy: strict-origin-when-cross-origin

Test:

- Click link → Check if sensitive info goes to another domain
- Should NOT send full URL with parameters

6 Permissions-Policy (Feature-Policy)

Purpose:

Controls browser features like camera, mic, geolocation, GPS, USB.

Example:

Permissions-Policy: camera=(), microphone=(), geolocation=()

Test:

- Try accessing camera/mic
- Should be blocked unless user consents

7 Cross-Origin-Opener-Policy (COOP)

Protects against cross-site attacks like **spectre**.

Example:

Cross-Origin-Opener-Policy: same-origin

8 Cross-Origin-Resource-Policy (CORP)

Prevents unauthorized loading of website resources.

Example:

Cross-Origin-Resource-Policy: same-origin



Cross-Origin-Embedder-Policy (COEP)

Used for security in modern JS features.

Example:

Cross-Origin-Embedder-Policy: require-corp



How to Test These Headers (Practical)



1. Using Browser Developer Tools (Easiest)

1. Open website
2. Press **F12** → **Network Tab**
3. Refresh page
4. Click first request
5. Check **Response Headers**

Look for:

- HSTS
- CSP
- X-Frame-Options
- Referrer-Policy
- Permissions-Policy
- Cookies security flags



2. Using Curl Command (Professional Testing)

Command:

```
curl -I https://example.com
```

This shows all headers.



3. Using Online Scanners

- securityheaders.com
- Observatory by Mozilla
- Pentest-tools

These give a grade (A, B, C, F).



Security Testing of Cookies (Very Important)

Cookies must have:



HttpOnly

Stops JavaScript from reading cookie → prevents XSS cookie theft.



Secure

Only sent on HTTPS.



SameSite

Stops CSRF attacks.

Good Example:

Set-Cookie: sessionid=abc123; Secure; HttpOnly; SameSite=Strict